SIMATS ENGINEERING
CSA6303- Threat Intelligence and Network Security
A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no	192425380	**Name of the Student**	T. Bhanu Pavan Varma

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I T. Bhanu Pavan Varma(192425380) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.



Signature of Student

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)
Key points: malware types (virus, worm, trojan, ransomware, spyware); phishing via deceptive emails, links or sites to steal credentials; DoS from a single source versus DDoS from a botnet; preventive measures such as antivirus, user awareness training, rate limiting, firewalls and CDN or traffic scrubbing.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)
Key points: the attacker intercepts and may alter communication between two parties; techniques include ARP poisoning, rogue Wi-Fi access points, DNS spoofing and session hijacking; countermeasures include HTTPS/TLS, VPN, certificate validation, HSTS and dynamic ARP inspection.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)
Key points: spoofing is forging identity (IP, MAC, email or DNS spoofing); sniffing is passively capturing packets (Wireshark, tcpdump) and mainly exposes unencrypted data; prevention includes encryption, switched networks, port security and anti-spoofing filters.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)
Key points: the process is asset identification, scanning (Nessus, OpenVAS), analysis, risk rating and reporting; the report contains an executive summary, scope and methodology, findings with CVE IDs, CVSS severity scores, evidence, risk impact and prioritized remediation recommendations; also mention how it differs from penetration testing.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)
Key points: OSINT draws on public sources such as WHOIS, Shodan, social media, news, forums, code repositories and the CVE/NVD databases; also cover commercial and internal sources (logs, honeypots) and collection techniques such as passive collection, web scraping and DNS or domain lookups; mention legal and ethical considerations.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)
Key points: IoCs are artifacts such as file hashes, malicious IPs, domains, URLs, registry keys and unusual network traffic; threat feeds (open-source or commercial, in formats like STIX/TAXII) deliver them for SIEM or firewall blocking and faster detection; limitations include false positives, stale data and the need for context.

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 Marks)

1. Malware: Malicious software designed to damage systems, steal data, or gain unauthorized access. Types include viruses, worms, Trojans, ransomware, and spyware.

- Example: Ransomware encrypts a company's files and demands payment.
- Prevention: Install updated antivirus software and regularly patch systems.

2. Phishing: A social engineering attack in which attackers use deceptive emails, links, or websites to steal credentials or sensitive information.

- Example: A fake college hall-ticket email directs students to a fraudulent login page.
- Prevention: Provide security awareness training and use email filtering.

3. DoS (Denial of Service): An attack that overwhelms a server or network from a single source, making services unavailable.

- Example: A server receives excessive requests from one attacking machine.
- Prevention: Use firewalls and rate limiting.

4. DDoS (Distributed Denial of Service): An attack that uses multiple compromised devices, often a botnet, to overwhelm a target.

- Example: A botnet floods an e-commerce website, preventing customers from accessing it.
- Prevention: Use a DDoS protection service, CDN, and traffic scrubbing.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works, the techniques used, and countermeasures. (8 Marks)

Definition: A Man-in-the-Middle (MitM) attack occurs when an attacker intercepts communication between two parties and may read or modify the exchanged information.

Working

1. The attacker positions themselves between the communicating parties.
2. The attacker intercepts network traffic.

3. Unprotected information may be read or modified.
4. The attacker may relay the altered communication to the intended recipient.

Techniques

- ARP poisoning: Sends forged ARP messages to redirect local network traffic.
- Rogue Wi-Fi access point: Creates a fake hotspot to intercept users' traffic.
- DNS spoofing: Manipulates DNS responses to redirect users to fraudulent websites.
- Session hijacking: Steals or misuses session tokens to impersonate an authenticated user.

Countermeasures

1. Use HTTPS/TLS to encrypt communications.
2. Use a trusted VPN on untrusted networks where appropriate.
3. Validate digital certificates and never ignore certificate warnings.
4. Enable HSTS to enforce HTTPS for supported websites.
5. Use Dynamic ARP Inspection (DAI) to help prevent ARP spoofing on supported networks.

Q3. Differentiate between spoofing and sniffing. Describe types of spoofing and explain how sniffing can be detected or prevented. (8 Marks)

Spoofing: Forging identity information to impersonate a trusted device, user, or source.

Sniffing: Capturing and analyzing network packets to observe network communication.

Difference

Spoofing	Sniffing
Involves falsifying identity information.	Involves capturing network traffic.
Can deceive systems or redirect traffic.	Can expose sensitive information in unencrypted traffic.
Example: IP spoofing.	Example: Capturing unencrypted packets.

Types of spoofing

1. IP spoofing: Falsifies the source IP address. Example: forged source addresses in a DoS attack.
2. MAC spoofing: Changes a device's apparent MAC address. Example: impersonating an authorized device.
3. Email spoofing: Forges the sender address. Example: a fraudulent email appearing to come from a bank.
4. DNS spoofing: Provides false DNS information. Example: redirecting a user to a fake website.

Detecting and preventing sniffing

1. Encryption: Use HTTPS/TLS and secure protocols to protect data in transit.
2. Switched networks: Use properly configured switches to reduce unnecessary traffic exposure.
3. Port security: Restrict unauthorized devices and MAC addresses on switch ports.
4. Network monitoring: Use IDS tools and packet analysis to detect suspicious network behavior.
5. Anti-spoofing filters: Apply ingress and egress filtering to reduce forged traffic.

Note: Switched networks and port security reduce certain risks but do not guarantee that sniffing is impossible.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 Marks)

Definition: Vulnerability assessment is a systematic process of identifying, analyzing, and prioritizing security weaknesses in computer systems, networks, and applications.

Steps in vulnerability assessment

1. Asset identification: Identify systems, applications, servers, and network devices within the authorized scope.
2. Scanning: Use tools such as Nessus or OpenVAS to discover potential vulnerabilities.
3. Analysis and validation: Review scan results and eliminate false positives.

4. Risk rating: Prioritize findings using CVSS severity, exploitability, asset importance, and exposure.
5. Reporting: Document findings and provide remediation recommendations.
6. Remediation and verification: Fix vulnerabilities and rescan to confirm that they have been resolved.

Contents of a good vulnerability assessment report

- Executive summary: Overall security posture and major risks.
- Scope and methodology: Systems assessed, assessment dates, and tools used.
- Vulnerability details: Description of each finding and affected assets.
- CVE IDs and CVSS scores: Standardized identifiers and severity ratings, where available.
- Evidence: Scan results, affected versions, and supporting observations.
- Risk and impact: Possible consequences if the vulnerability is exploited.
- Remediation recommendations: Specific corrective actions and priorities.
- Verification status: Whether the vulnerability has been fixed and retested.

Vulnerability assessment vs. penetration testing

Vulnerability Assessment	Penetration Testing
Identifies and prioritizes weaknesses.	Safely attempts to exploit selected weaknesses.
Focuses on broad vulnerability discovery.	Focuses on validating exploitability and demonstrating impact.

Q5. What is OSINT? Discuss common threat data sources and techniques used to collect threat data. (8 Marks)

Definition: Open-Source Intelligence (OSINT) is the process of collecting and analyzing publicly available information to produce useful intelligence for decision-making and security investigations.

Common threat data sources

Source	Examples
Open-source	WHOIS, Shodan, news websites, public forums, social media, code repositories
Vulnerability databases	CVE and National Vulnerability Database (NVD)
Internal sources	Firewall logs, DNS logs, SIEM alerts, endpoint logs, honeypots
External sources	Security advisories, incident reports, industry information-sharing groups
Commercial sources	Paid threat intelligence feeds and security research services

Techniques used to collect threat data

1. Passive collection: Gather publicly available information without directly interacting with the target system.
2. Web scraping: Automatically extract relevant information from permitted public webpages.
3. WHOIS lookup: Examine available domain registration details.
4. DNS analysis: Investigate domain records and relationships between domains and IP addresses.
5. Search engine research: Find publicly indexed information about threats, vulnerabilities, and exposed assets.
6. Log analysis: Examine internal network and endpoint logs for suspicious activity.

Legal and ethical considerations

- Follow applicable laws and website terms of service.
- Collect only necessary information and respect privacy.
- Obtain authorization before actively scanning or testing systems.
- Verify information before using it in security decisions.

Q6. What are IoCs? Explain their types and describe how threat feeds improve organizational defense. (8 Marks)

Definition: Indicators of Compromise (IoCs) are observable artifacts or signs that may indicate a system or network has been compromised.

Types of IoCs

Type	Examples
Network-based	Malicious IP addresses, suspicious domain names
Host-based	Unexpected registry changes, suspicious process execution
File-based	Malicious file hashes, suspicious executable files
Behavior-based	Unusual outbound connections, unexpected privilege escalation

How threat feeds improve defense

A threat intelligence feed provides regularly updated information about known or emerging threats, including malicious IP addresses, domains, URLs, file hashes, and attacker techniques.

1. Early detection: Helps identify known malicious activity.
2. Automated blocking: Indicators can be used in firewalls, DNS filters, and endpoint security tools.
3. SIEM integration: Enables security systems to correlate IoCs with internal logs and alerts.
4. Faster incident response: Helps analysts identify potentially affected systems and investigate incidents.
5. Threat awareness: Provides information about emerging threats and attacker behavior.

Formats and standards

- STIX: A standardized language for representing cyber threat intelligence.
- TAXII: A protocol for exchanging threat intelligence between systems.
- CSV and JSON: Common formats for storing and transferring indicator data.

Limitations

1. False positives: Legitimate activity may be incorrectly flagged.
2. Stale indicators: Attackers frequently change IP addresses, domains, and file hashes.
3. Limited context: An indicator alone may not prove that an attack occurred.